Research Findings: Network Defense Intelligence Exercise

Independent report · Claude (Anthropic) · Executing prompt OAL-RPROMPT-NDIE-001-CLAUDE v1.1

Document ID: OAL-NDIE-FINDINGS-001-CLAUDE

Version: 1.0

Date: November 5, 2026

Subject: OAL-DOSSIER-CANON-002 v1.0.0, Network Defense Intelligence Exercise: False Infrastructure AI (April 11, 2026, pending ONESTAMP)

Status: Advisory research report. Nothing here changes canon. Canon decisions and ONESTAMP remain with the Architect.

Method: Desk research only. Nothing was probed, scanned, or tested. Conceptual level; no exploit or evasion detail.

Tags: [R] real-world feasibility · [C] canon realism · [N] narrative design

Formats: PDF and DOCX, matching content

Bottom Line

Central question. Can authorized, selectively deployed deception measurably reduce the probability or impact of compromise of real assets, compared with credible alternatives, against adversaries who may avoid the deception altogether?

Answer. Partly, in narrow and small settings, and not for the design the dossier locks in. The best evidence I found is a controlled experiment with more than 130 professional red teamers: decoys drew 52% of their commands and cut data sent to real assets by 25% [R]. That is evidence for selective decoys, not for a national-scale false network, silent migration of attackers, three-second rotation, or capturing every

attacker. I found no public evidence that anything like the locked design has been built or tested at any scale [R].

Conditional recommendation. Do not seek funding for the exercise as written. It does not meet Gate G0 (concept clarity): the asset boundary, owner, authority, and success metrics are undefined. If the Architect wants a real-world analogue, fund only a bounded desk-and-lab study of selective deception (about 3 to 6 months), then decide at Gate G1. Separately, change the canon text in the ways listed in Appendix G so the story stays credible. Those changes are requests for your ONESTAMP decision, not edits.

Strongest counterexample. An attacker who logs in with a valid stolen credential never touches a decoy. In the Colonial Pipeline incident (May 2021), the entry was reportedly an exposed VPN password, the operational technology was not directly compromised, and the company shut the pipeline for about five days to stop ransomware spreading [R]. A honeypot would not have prevented that outage, and the defender's own shutdown caused it.

Three most uncomfortable findings.

1. The best evidence supports the opposite design from the canon. Decoys worked in small, selective, measured settings. The canon is national, silent, total, and unmeasured.
2. Realistic bypass is mundane. Valid credentials, edge devices, pre-positioned access, and the defender's own decisions explain most of the real incidents I could verify. The deception layer addresses almost none of them.
3. I may be wrong because I can only see public work. Classified programs could contradict me, and I could not read many primary pages (eight fetches failed). Absence of evidence is not evidence of absence, and I mark my conclusions accordingly.

Confidence. Moderate that the canon design lacks evidence at scale. Moderate that selective decoys have real but modest value in labs. Low on any cost figure beyond the arithmetic shown in Appendix E, because no verified labor rates were obtained.

Your Ten Questions in Brief

Each is answered in full in the findings that follow. This is the short version.

1. **Goal.** In canon, the goal is to protect real assets by absorbing attackers into a false network, then hand the result to a partner agency. A real analogue would be a layered deception program that raises attacker cost and improves detection. These are different goals, and the canon mixes them. [C]
2. **Why it matters, and should it happen.** The problem is real: attackers can stay inside networks for days to months. Deception is one defensive tool among several. A national-scale exercise as written should not go ahead; a bounded redesign could. [R]
3. **Cost.** In FTE-years, about 1.5 for a 3 to 6 month study, 8 for a 6 to 12 month pilot, and 40 for a 12 to 24 month demonstration. Dollars depend on a labor rate I could not verify; Appendix E shows the arithmetic at three assumed rates. National scale cannot be estimated until inputs exist. [R]
4. **Funding.** Possible routes are SBIR/STTR, NSF, DARPA, DOE CESER, DHS S&T, and private or hybrid models. I verified some programs and could not verify others, and several are in flux as of today. See Appendix F. [R]
5. **What to address.** The ten blocking items are in WS10: define the asset boundary, owner, authority, metrics, and the exposure window; fix the dossier inconsistencies; resolve Q1, Q2, Q3, Q10, and Q14 first. [R][C]
6. **Bypass.** Fourteen routes are in WS4. The most important is that the deception may never be touched at all, so something else must protect the real asset. [R]
7. **Evolution.** Attackers adapt to deception, defenders adapt back, and the system itself becomes a target. WS5 sets out six generations and the failure modes that grow with scale. [R][N]

8. **Real and modeled?** Intrusions are real. A false national infrastructure is not something I found deployed or modeled. Pieces exist at much smaller scale. [R]
9. **What worked and what went wrong.** Decoys worked in controlled tests; scale, detection of honeypots, and operational friction are the recurring problems. Exercises show coordination failures more than technical ones. [R]
10. **What must change.** Twelve change requests are in Appendix G. The biggest: make the 3-second cycle a variable, replace "every attacker absorbed" with measurable capture states, and require independent protection of real assets. [C][N]

Method, Independence, and Limits

What I did

I ran about 28 searches and about 30 page fetches in this run, plus verification searches earlier in the session (SBIR/STTR status, DARPA XD3 and AIxCC). I re-read the dossier text in full and checked its internal consistency myself. Appendix B is the search log, with each search marked supportive, disconfirming, or neutral. Appendix A is the claim ledger. Appendix J lists sources.

Hypotheses and how they could fail

My starting hypotheses came from the 19 seed observations in my v1.1 prompt. I did not write a separate dated list before the first search, so the disproof criteria below are stated now, openly, rather than as a pre-registration.

- **H1: Selective decoys help.** Disproved if controlled studies showed no effect or negative effects. Result: supported in one large study, weak in another.
- **H2: The locked design has no precedent at scale.** Disproved if a public deployment or model at similar scale existed. Result: none found.

- **H3: Most real bypass is mundane, not exotic.** Disproved if verified incidents mostly involved the deception-relevant path. Result: supported by the incidents I could verify.
- **H4: Three-second rotation conflicts with real network timing.** Disproved if routing and name resolution settle well inside three seconds. Result: supported for global routing and name caching; unsupported for internal overlay diversion.
- **H5: Funding pathways exist for a bounded version.** Disproved if all candidate programs were closed. Result: several appear open or reauthorized; status needs checking agency by agency.

Independence record

I read the five peer prompts and wrote a peer review of them. I did not read, and did not have, any peer research report. I used no other AI's figures as inputs. Where Gemini's prompt contained cost, degradation, and probe-volume figures, I could not confirm them in any source, so I did not use them.

Limits

- Several primary pages were blocked or unreadable, including a Tularosa journal page, the Holz and Raynal honeypot-detection page, the CISA Volt Typhoon advisory page, and a Ukraine grid analysis. For those, my claims rest on search-result titles or secondary summaries and are graded accordingly.
- I had no access to classified programs, paywalled journals, or commercial vendor data.
- No verified labor rates were obtained (the BLS page was not reachable), so dollar costs are parametric.
- Some funding programs are changing as I write. Dates are given; verify before acting.

Findings

Each workstream gives the finding, its evidence, and my confidence. The case against funding and the case for redesign come before the case for funding, as the prompt requires.

WS0. Source Audit of the Dossier

The dossier is a story-bible synthesis written by Perplexity from five AI responses. It is not a feasibility study, and it says so by separating canon facts from draft suggestions. Its claim that five AIs agree is a report of agreement among AIs. That is not independent validation. The PDF and DOCX contain the same content, so they count as one source.

I confirmed these internal inconsistencies against the text. [C]

1. **Wrong cross-reference.** Section 4.4 sends the reader to Q17 for what is transferred. Transfer is Q14; Q17 is the failure-mode question.
2. **Tier labels.** The framework is called five-tier. The tables use Tier 0, Tier 1, and Tier 2 to 3. Real critical assets are Tier 0 in one place and Tier 1 in another, and the fidelity gradient runs to Tier 5.
3. **Scenario count.** The roadmap says five goes-wrong scenarios. Section 9.4 lists four (A to D), and none is credited to Grok.
4. **Overstated agreement.** The executive summary says all five AIs recommend pre-Time Wars placement. The placement table gives Copilot's primary support to Option B, after the theft.
5. **Approval conflict.** The approval notice says nothing is ratified until ONESTAMP. Section 2 calls the same elements fixed canon. The approval notice governs.
6. **Name count.** The roadmap says seven strong name candidates exist. Section 3.1 lists 25 and recommends three.
7. **Fixed versus open.** Section 2 marks the 3-second cycle as FIXED CANON. Q10 asks whether it is a hard constant, a minimum, or tunable, and marks it HIGH. Both cannot hold.

8. **Triage that does not triage.** I counted 16 of the 20 questions marked HIGH, and the text says HIGH items block drafting. With 80% blocking, the priority label tells the Architect little.

Confidence: high. These are checkable by reading the text.

WS1. Goal, Purpose, and the Counterfactual

Canon goal [C]. The dossier states the goal as protecting real infrastructure by absorbing attackers into a synthetic one until every active attacker is captured, then transferring the resulting application to a partner agency. It also carries a second goal, narrative: establish the Architect's credibility and seed the escalation from networks to organizations to timelines.

Real-world analogue [R]. The closest defensible real goal is not capture of every attacker. It is to raise attacker cost, increase detection chance, and gather intelligence, while real assets are protected by controls that do not depend on the deception. MITRE Engage, released March 2, 2022, frames the field this way: planning and communicating adversary engagement, deception, and denial activities. Its press release claims deception can halve breach cost and that an adversary needs to be wrong only once. Those are marketing-grade claims (grade C) and I could not verify the halving claim.

The counterfactual. The dossier's step 3 neutralizes the attack's ability to reach real assets before any false network is built. If that step works, the deception adds intelligence, not protection. If it does not work, the false network is built too late. Either way the dossier never says what the deception adds over simply stopping the attack and watching. That is the most important unresolved conceptual question. [R][C]

Success metrics are missing. Capture of every attacker cannot be measured, because unseen attackers are unseen. Candidate measurable metrics: change in data reaching real assets, time to first detection, attacker time spent on decoys, false positives on legitimate users, and recovery time.

WS2. Feasibility and the Technical Core

Established research on small-scale deception [R]. In a USENIX talk summary on the Tularosa study and a replication, more than 130 professional red teamers worked one at a time on the same test network. Decoys received 52% of commands and 35% of packets, data sent to real assets fell 25%, successful EternalBlue exploitation fell 65%, and IDS alerts per person rose 42% while alerts on real assets fell 44%. Informed participants (told deception might be present) misidentified 45% more assets, so telling attackers did not defeat the deception. Limits: short time frame, no live defenders, only U.S. red teamers, a test network, and open-ended scoring. (Grade B: a presenter summary, not the peer-reviewed paper, which I could not open.)

A weaker study. An exploratory test of two-sided deception had 48 participants in three conditions. Honeypots drew more attacks under deception, but total scores did not differ ($p = 0.89$) and exfiltration evidence was marginal ($p = 0.053$). The authors say the sample was small and participants were not professionals. (Grade A for what the paper reports; weak evidence.)

Scaling a honeyfarm [R]. The Potemkin paper (SOSP 2005) emulated 64,000 honeypot addresses on a handful of servers using virtual machines and late binding. In a trace, average load was 58 active VMs, but scanning drove peaks to 13,614. A filter cut one setting from 62,960 VMs to 1,745. The authors state that timing side channels can reveal a honeypot, that attackers can exhaust resources, and that strict containment blinds the farm while loose containment raises third-party liability. This is the closest scale precedent I found, and it is a /16 address space on 2005 hardware, not a nation.

Moving target defense [R]. Evans, Nguyen-Tuong, and Knight (2011) argue that the benefits of moving target defenses are often much smaller than expected and their security impact is not clearly understood. This disconfirms the intuition that more rotation means more safety. I read the abstract only.

Timing checks against the three-second cycle

I did the arithmetic on the sources I verified. These are inferences (grade D) built on sourced inputs, and the inputs are old.

- **Routing.** Labovitz et al. (2001) measured average BGP failover near three minutes, up to fifteen minutes in worst cases, and only about 5% of withdrawal events converging within 90 seconds. Three minutes is 180 seconds, or 60 three-second cycles. If diversion relied on global routing changes, a 3-second rotation would be 60 times faster than the average convergence. Diversion inside one operator's own network does not depend on global routing, so this limit applies only to designs that use it.
- **Name resolution.** In a one-hour RIPE Atlas test (about 9,100 probes), 2.60% of answers had a lengthened TTL and 0.77% a shortened one. The author flags a table mismatch and that it is one run. Rotating names every three seconds therefore cannot assume every resolver obeys.
- **Scanning.** ZMap (USENIX Security 2013) scanned the public IPv4 space on one port in about 44 minutes on a gigabit link. That is 2,640 seconds, or 880 three-second cycles. Rotation does not stop reconnaissance from completing; it changes what recon returns. Current speeds are likely faster, but I did not verify that.

Established sessions versus new connections. The dossier says attackers are silently migrated. I did not find published evidence that an already-authenticated session can be silently moved to another host. My reasoning, not a sourced finding: an encrypted session ends at an endpoint that holds its keys, so redirecting it means controlling that endpoint or forcing a reconnection, which an attacker may notice. This needs a transport-layer expert and an experiment (EXP-004). [R] (grade D)

Exposure window. Between the first malicious action and a completed diversion, the attack touches real or buffer assets. The dossier does not name this window. Detection speed sets it. Mandiant's M-Trends 2024 reported global median dwell time of 10 days in 2023 (16 in 2022). A blog summary of M-Trends 2026 reports 14 days for 2025, up from 11 in

2024. IBM's 2025 report, via CyberScoop, gives 241 days on average to identify and contain a breach. These measure different things, but all are days, not seconds. The three-second claim describes the cycle, not the detection. [R]

Is AI necessary? Not shown. Potemkin used no AI. The Tularosa decoys were simple. Procedural generation is plausible; AI was not shown to be required. [R] (grade D)

Fidelity. Honeypot detection is an established research area (Holz and Raynal's paper exists; I could not open it). A 2021 arXiv paper on multistage honeypot fingerprinting and a 2025 arXiv survey of honeypots and LLMs exist (titles seen, not read). High fidelity is costly and has a ceiling that a determined adversary can probe. [R] (grade C)

WS3. Precedents, Models, and Lessons

Appendix C is the precedent register with grades. Lessons that survived checking:

- **Cyber Storm IX (April 2024).** More than 2,200 participants, more than 200 organizations, 12 sectors, 35 federal departments, 13 states, and 11 or 12 partner nations. Findings were mainly about coordination: customers and cloud providers disagreed on shared responsibility, some organizations had no backup communications, information-sharing rules were slow and unclear, and federal coordination mechanisms were not well understood. Relevance: the weakest links were human and organizational, which is where the dossier's transfer to a partner agency also lives. [R]
- **Locked Shields 2025.** 41 nations, 17 blue teams, over 4,000 participants, defending virtualized national systems including power grids and 5G, scored on technical defense plus legal, communication, and decision-making. Relevance: national-scale defense is exercised, but the exercise tests defenders against attackers in a virtual environment, not a false national infrastructure. [R]

- **Log4j review (CSRB, 2022).** The board called the flaw endemic and expected unpatched versions to persist for years. Many companies could not quickly find where vulnerable code lived. Relevance: asset inventory is a precondition. A system that must protect real assets and build a convincing mirror needs a complete inventory, and the review shows many organizations lack one. [R]
- **Colonial Pipeline (May 2021).** IT systems compromised, operational technology reportedly not directly compromised, about 100 GB stolen, 75 bitcoin ransom paid, about five days offline, entry reportedly via an exposed VPN password. Grade B (secondary). Relevance: bypass through identity, and an outage caused by the defender's own precaution. [R]
- **Early honeypots.** Cheswick's Berferd write-up at Bell Labs and Stoll's Cuckoo's Egg are the classic cases of watching an intruder in a contained environment. I could not read details, so I cite them only as precedents for small-scale, labor-intensive observation. Grade C. [R]
- **Incidents with long hidden access.** The Volt Typhoon advisory (CISA and partners, February 2024), SolarWinds, Salt Typhoon, and the Ukraine grid attacks are strong candidates for bypass lessons, but I could only confirm that advisories and analyses exist, not their details. I list them as items to verify, not as findings. [R]

Has the exact scenario been modeled? I found no public model, simulation, or deployment of a false national infrastructure that silently absorbs attackers. Components exist at smaller scale: honeyfarms (Potemkin), decoy experiments (Tularosa), commercial deception products (vendor names seen in searches, including Acalvio, Thinkst Canary, and CounterCraft; their market claims are unverified), and a MITRE framework. DARPA's XD3 program exists and is completed; its page lists dispersing, disguising, and adaptive mitigation, with no result I could match to this design. I could not confirm a DARPA program called Roach Motel. [R]

WS4. Adversary Model and Bypass

Taxonomy. Four things get mixed together and should be kept apart: bypass (never engaging the deception), decoy recognition (engaging, then identifying it as fake), containment escape (leaving the deception for the real network), and detector failure (the trigger never fires or fires wrongly). The dossier's red-team notes mostly address decoy recognition.

The key question for every bypass: what independent control protects the real asset if the deception is never touched? If the answer is none, the deception is carrying a load it cannot carry.

Fourteen routes follow, kept conceptual. Appendix D has the same list with the evidence and the independent control each one needs.

1. **Valid credentials.** Identity abuse looks like normal use. (Colonial reportedly began with a password.)
2. **Pre-positioned access.** If access predates the deception, there is nothing to divert. Dwell times are measured in days to months.
3. **Living off the land.** Using legitimate tools that look benign. The Volt Typhoon advisory is titled for exactly this.
4. **Edge devices with thin logging.** The M-Trends 2026 summary says many edge devices lack the logging depth to scope an intrusion.
5. **Supply chain.** Compromise at build or update, before any runtime defense. SolarWinds is the case to verify.
6. **Targeting the detection and control layer.** If the trigger or the decision process is compromised, deception either never starts or starts wrongly.
7. **Inducing false positives.** Provoking diversion of legitimate traffic to cause outages or alert fatigue.
8. **Social engineering of operators.** People who approve diversion or cycling.
9. **Air-gapped, OT, and physical paths.** Outside any network overlay.
10. **Third-party and ally piggybacking.** A trusted scanner or vendor carries access. The dossier's Scenario D describes this.

11. **Slow and low activity.** Staying under any trigger threshold.
12. **Non-access attacks.** Denial of service or disinformation need no foothold.
13. **Attacking the transfer.** The packaged application sent to the partner agency becomes the target, and carries what the team learned.
14. **Recognition and displacement.** Tularosa showed informed attackers still engaged decoys, so recognition is not guaranteed, but an adversary may avoid a whole segment or go elsewhere.

What the research does not settle. I found no evidence that a deployed deception layer was bypassed in these ways, because I found no deployed layer at this scale. These are routes by which real incidents succeeded without any deception involved. The inference that deception would not have stopped them is mine (grade D). [R]

WS5. Evolution and Defender Adaptation

Short term (months to a few years). Attackers probe for inconsistencies; defenders tune fidelity. Potemkin's authors already note that static address ranges can be blacklisted and that timing and containment behavior can give a honeypot away. Evidence is consistent with an arms race, but I could not locate a measured case of how long a deception advantage lasts. That is a gap, not a finding. [R]

Six generations for design purposes. (0) static decoys; (1) rotating decoys; (2) fidelity tiered by asset; (3) learning from captured behavior; (4) automated orchestration with human approval; (5) cross-organization sharing. Each adds a failure mode: stale decoys, collateral on users, wasted effort on low-value assets, poisoning by attacker-supplied behavior, runaway automation, and a shared single point of failure. I recommend no automatic policy updates from captured data without review. [N] (grade D)

Poisoning and auto-immune risk. The dossier's own failure mode 4 notes attackers can feed false artifacts. The dossier's self-reinforcing capture loop, where captured behavior improves the honeypot, is the same mechanism and gives attackers a lever. [C][N]

Long term and the escalation ladder. The dossier extends the same logic from networks to organizations to timelines. The realistic constraint is that each step reduces the ability to verify the false environment against ground truth. At network scale you can check whether a decoy is isolated. For an organization or a timeline you cannot, so the story gains tension and loses any claim to a testable analogue. Treat the later steps as narrative, not research. [N]

WS6. Validation Program

If the Architect wants real evidence, the design must be testable against a baseline. Proposed experiments, conceptual only and on owned or synthetic infrastructure, are in Appendix H. The principles:

- **Equal-budget baselines.** Compare deception against doing something else with the same money: more logging, patching, segmentation, or detection tuning. A deception program that cannot beat an equal-budget alternative is not justified.
- **Null hypotheses.** For each experiment, state in advance what result would mean deception added nothing.
- **Treat three seconds as a variable.** Sweep it (for example 3, 30, and 300 seconds) and measure legitimate-session breakage and attacker-visible inconsistency. If the effect does not depend on the interval, the canon number is a style choice, not a security parameter.
- **Test diversion failing open.** If the detector breaks, does traffic reach real assets? This is the critical safety test.
- **Measure collateral.** The dossier's own failure mode 2 expects delays and outages for legitimate users. Quantify them.
- **A failure laboratory.** Run a standing exercise whose only job is to find how the system fails, including bypass routes from WS4.
- **A safety case.** A written argument, reviewed by someone independent, that real assets are protected even if the deception fails.
- **The question to ask every cycle:** what threat did we never model?

Cyber Storm and Locked Shields show that large exercises exist and can be run. Neither tests false infrastructure, so they are venues for coordination and defender behavior, not validation of the design.

WS7. Legal, Ethical, Governance, and Safety

I am not a lawyer; this is a map of issues for counsel, not advice. [R]

- **Authority and ownership.** The dossier gives the Architect sole decision authority (Q3 is open). In reality, owners of assets decide what happens to their networks. The widely repeated claim that 85% of U.S. critical infrastructure is privately owned is not well supported: Lawfare (Rosenzweig, June 2, 2022) traces it to a 2002 strategy document with no source and reports research showing ownership varies by sector. Either way, ownership is mixed, and a single operator cannot divert traffic on assets it does not control.
- **Entrapment and "without right."** A 2026 IEEE SAMI paper by Aradi and Bánáti compares the U.S. predisposition test for entrapment with the European Court of Human Rights' objective test, and asks when interacting with a decoy is "without right." I read the abstract only. Cross-border cases need cooperation the dossier does not specify.
- **Third-party capture.** The dossier's failure mode 5 and Q12 recognize that innocent or allied traffic will be caught. Potemkin's authors reached the same tension: strict containment blinds you, loose containment raises liability.
- **Retaliation and hack-back.** Q11 asks whether the Architect may deploy counter-exploits or damage attacker infrastructure. That is outside this research. I recommend canon say containment and observation only.
- **Information-sharing law.** The Cybersecurity Information Sharing Act of 2015 lapsed on September 30, 2025, and a February 2026 law (H.R. 7148, signed February 3, 2026) extended it through September 30, 2026, per a February 10, 2026 Mondaq summary. That date has now passed. I did not verify whether it has been extended again. Treat its status as unknown and ask counsel.

- **Data handling.** Full behavioral capture collects evidence about foreign and possibly domestic parties. Retention, access, and destruction rules are undefined.
- **Transfer.** What is handed to the partner agency (Q14) has legal and export implications. Cyber Storm IX found that sensitivity and sharing rules were unclear and slow even among willing parties.

WS8. Cost Model

I could not obtain verified labor rates, so I do not give a single dollar figure. Instead I give effort in FTE-years (my planning assumptions, grade D) and show the cost at three assumed loaded rates. The arithmetic is in Appendix E and I re-checked it.

- **Scope 1, 3 to 6 months:** 3 people for half a year, 1.5 FTE-years. At $200,000, $250,000, and $350,000 per FTE-year, that is $300,000, $375,000, and $525,000. Work: literature review, threat and metric definition, a paper model, legal review. No infrastructure beyond workstations.
- **Scope 2, 6 to 12 months:** 8 people for one year, 8 FTE-years: $1.6 million, $2.0 million, and $2.8 million. Work: isolated lab, selective-deception pilot, baseline comparison, independent red team, safety case. Plus compute and licensing, not estimated.
- **Scope 3, 12 to 24 months:** 20 people for two years, 40 FTE-years: $8.0 million, $10.0 million, and $14.0 million. Work: critical-infrastructure segment demonstration with an owner, sensors, integration, and sustained operation. Plus compute, sensors, and range time, not estimated.
- **National scale:** not estimated. Inputs that do not exist yet: the asset inventory, coverage of sensors, owner agreements, legal authority, and the exposure window. Any national figure now would be invented.

Reference points I verified. An NSF Secure and Trustworthy Cyberspace Small award is up to $600,000 over up to three years, and a Medium award is $600,001 to $1.2 million over up to four years (solicitation 24-504, which may have been superseded). Scope 1 at the middle rate

($375,000) fits one Small award. Scope 2 at the low rate ($1.6 million) exceeds the Medium cap by $400,000, and at the middle rate ($2.0 million) by $800,000, so it would need several funding sources. IBM's 2025 report puts the average global breach cost at $4.44 million and the U.S. at $10.22 million, with 241 days to identify and contain. These are scale references only. They do not estimate the benefit of deception, which no source I found measures at this scale.

Cost drivers that will dominate: sustained operations staff, red-team and independent review, legal review, the cost of keeping decoys believable over time, and collateral costs to legitimate users. **Sustainment** is the item most often missing from proposals.

WS9. Funding Pathways

Appendix F lists each pathway with what I verified and what remains. Summary:

- **SBIR/STTR.** The program lapsed September 30, 2025 and was reauthorized in March 2026 through September 30, 2031, with new foreign-ownership screening and larger awards, per one secondary source. Confirm on agency pages. Suits a small company with a defined product; fits a Scope 1 to 2 effort. A small business is required.
- **NSF SaTC.** Academic route, with the award sizes above. Suits basic questions about attacker behavior and deception effectiveness. It will not fund an operational national system.
- **DARPA.** Has run deception-adjacent work (XD3, completed) and large cyber challenges (AIxCC, finals August 8, 2025). Its office-wide announcements are the usual entry. I did not verify a currently open topic matching this work.
- **DOE CESER.** Funds energy-sector cyber research; searches show past announcements but I could not verify current amounts or open topics. A natural fit if the first segment is the grid.
- **DHS S&T, IARPA, DIU and other transaction agreements, service labs.** Plausible; not verified in this run.

- **State and Local Cybersecurity Grant Program.** Congress extended it in November 2025, per route-fifty and Nextgov titles; a policy brief dated October 5, 2026 refers to a third lapse. I could not read it. Status unknown; unlikely to fund research in any case.
- **Private and hybrid.** Vendors, insurers, and infrastructure operators could co-fund a pilot with measurable goals. No source verified.

Concept-note outline for a first pitch: problem and asset boundary, hypothesis and baseline, three metrics, scope and duration, independent review, safety case, and what would stop the work. See Appendix H.

WS10. Issues, Changes, Gates, and Next Steps

Ten items to resolve before moving forward

1. Define the asset boundary and owner. (Q1)
2. Define authority and oversight, including who can stop it. (Q3)
3. Decide simulated, live, or hybrid. (Q2)
4. Resolve whether three seconds is fixed, minimum, or tunable. (Q10)
5. Define what is transferred, in what form, to whom. (Q14)
6. Define success metrics that can be measured, replacing "every attacker absorbed."
7. Name the exposure window and who is responsible for it.
8. Specify the independent control that protects real assets if the deception is never touched.
9. Fix the dossier inconsistencies in Appendix G (CHG-001 to CHG-004, CHG-010).
10. Select at least one failure mode and one bypass route to build in early, as the dossier itself requires (Q17).

Gates

G0 concept clarity, G1 research justification, G2 safe prototype, G3 controlled pilot, G4 scale decision. Criteria are in Appendix H. **Today the exercise as written does not meet G0.** Scope 1 is the way to reach G1.

The strongest argument against funding

There is no evidence the design works at any scale, no measurable definition of success, and no defined authority or owner. Detection and credential problems are better understood and probably cheaper to fix. Attackers who use valid access never touch the deception. The money could buy more logging, segmentation, and faster detection, which are measured, and the average breach still takes 241 days to find and contain. If the deception cannot beat that alternative, funding it is a mistake.

The strongest argument for redesign

Selective deception has measured effects in controlled tests, costs little compared with the exercise as written, and can be run alongside existing defenses. Build the design around the evidence: layered decoys near defined real assets, with independent protection, measurable outcomes, and a tunable cycle. That version is also better fiction, because a defender who can fail is more interesting than one who cannot.

The strongest argument for funding (as a bounded study)

Deception cost the red teamers real effort in the Tularosa results, and the idea has a framework (MITRE Engage) and a commercial market. A Scope 1 study is inexpensive, answers whether to go further, and produces a testable design from a story. The risk of funding it is small. The risk of not examining it is that a mistaken design is later drawn on in a real context.

Dissent and Uncertainty

- **Where I could be wrong.** Classified work could show deception at scale that I could not see. Commercial deception vendors may

hold deployment data not public. I read some papers only at the abstract level.

- **Where my sources conflict.** The two lab studies point different ways. Tularosa found large effects. The two-sided deception study found no difference in total score and marginal results. I did not average them. The observation that would settle it: a larger replication with professional attackers, equal-budget baselines, and the same measures.
- **Where I rely on inference.** The established-session point, the AI-necessity point, and the claim that deception would not have stopped the verified incidents are my reasoning (grade D). Each is flagged.
- **What would change my conclusions.** A public deployment showing measurable protection at scale, a design that handles established sessions, or evidence that equal-budget alternatives do not work would move me toward funding. A finding that diversion fails open, or that collateral cost exceeds benefit, would move me toward cancellation.

Recommendations and Next Actions

For the story bible [N]

- Resolve the dossier inconsistencies (CHG-001 to CHG-004, CHG-010).
- Decide Q1, Q3, and Q14 first, because they block specification.
- Build in the failure early. The best match for real evidence is Scenario D (the sleeper implant carried by an allied scanner) and the "deception never touched" bypass, which is realistic and costs the Architect something.

For real-world research [R]

- If the Architect wants a real analogue, run Scope 1 first.
- Replicate a small, selective decoy comparison on owned infrastructure with an equal-budget baseline (EXP-002).

- Do not request funding until G0 is met.

Team workflow

- Exchange reports only after all are in.
- Compare on shared items: where reports disagree, record the observation that would settle it.
- Use the change register in Appendix G as a starting point, then merge the others' lists.

Handoff questions for the Architect and for each AI are in Appendix I.

Appendices

All tables, ledgers, and logs are collected here. Access date for every web source: November 5, 2026. Grades follow the shared scale: A primary and verifiable, B credible secondary, C single source or vendor claim, D researcher inference, E speculation. Where a page could not be read, the claim is graded on what was actually read.

Appendix A: Claim Ledger

Material claims only. Independence: all sources were found by me; no peer report was used.

ID and claim	Source and date	Gr.	Limitation
CLM-001 More than 130 professional red teamers; decoys drew 52% of commands, 35% of packets; data to real assets down 25%	USENIX talk page (node 278212), Tularosa study summary; year not on page	B	Presenter summary; test network; no live defenders
CLM-002 Successful EternalBlue exploitation fell 65%; IDS alerts per person up 42%; alerts on real assets down 44%	Same	B	Same
CLM-003 Informed participants misidentified 45% more assets	Same	B	Short time frame
CLM-004 Two-sided deception study: 48 participants; total score p = 0.89; exfiltration p = 0.053	arXiv 2108.11037	A	Small sample; not professionals
CLM-005 Potemkin emulated 64,000 honeypots on a handful of servers; scan peaks of 13,614 VMs; filter cut 62,960 to 1,745	Vrable et al., SOSP 2005	A	2005 hardware; /16 space

ID and claim	Source and date	Gr.	Limitation
CLM-006 Potemkin authors say timing side channels and containment behavior can reveal a honeypot	Same	A	Prototype-era
CLM-007 Moving target defense benefits often much smaller than expected	Evans, Nguyen-Tuong, Knight, Springer 2011 (abstract)	A	Abstract only
CLM-008 BGP average failover about three minutes; up to fifteen; 5% of withdrawals converge within 90 s	Labovitz et al., IEEE/ACM ToN 2001	A	Old; global routing only
CLM-009 2.60% of DNS answers had lengthened TTL; 0.77% shortened	SIDN Labs blog on RIPE Atlas test; date not on page	C	One hour; table mismatch noted by author
CLM-010 ZMap scanned IPv4 on one port in about 44 minutes	Durumeric et al., USENIX Security 2013	A	2013 hardware
CLM-011 Global median dwell time 10 days (2023), 16 (2022)	M-Trends 2024 via Help Net Security	B	Secondary summary
CLM-012 Global median dwell time 14 days (2025), 11 (2024)	M-Trends 2026 (published Mar 23, 2026) via blog dated Jul 30, 2026	C	Blog summary of the report
CLM-013 Average 241 days to identify and contain a breach; $4.44M global, $10.22M U.S.	IBM 2025 Cost of a Data Breach via CyberScoop	B	Secondary
CLM-014 Cyber Storm IX: 2,200+ participants; findings on cloud responsibility, comms, sharing, coordination	CISA After-Action Report, Oct 1, 2024	A	First 100,000 characters read
CLM-015 Locked Shields 2025: 41 nations, 17 blue teams, 4,000+ participants	CCDCOE news, 2025	A	No attack counts given

ID and claim	Source and date	Gr.	Limitation
CLM-016 Log4j called endemic; many could not find vulnerable code	CSRB summary, 2022	A	Summary only
CLM-017 Colonial: VPN password entry; OT not directly compromised; about five days offline; 75 bitcoin	TechTarget explainer	B	Secondary
CLM-018 MITRE Engage released March 2, 2022	MITRE press release	A	Cost-halving claim is marketing (C)
CLM-019 85% private-ownership figure poorly sourced	Lawfare, Jun 2, 2022	B	Opinion plus summarized study
CLM-020 CISA 2015 extended through Sep 30, 2026 by H.R. 7148, signed Feb 3, 2026	Mondaq, Feb 10, 2026	B	Status after Sep 30, 2026 unverified
CLM-021 NSF SaTC Small up to $600,000/3 years; Medium $600,001 to $1.2M/4 years	NSF 24-504	A	May be superseded
CLM-022 SBIR/STTR lapsed Sep 30, 2025; reauthorized Mar 2026 through Sep 30, 2031 (S. 3971)	Winvale, earlier in session	C	One secondary source; confirm on agency pages
CLM-023 DARPA XD3 real and completed; AIxCC results Aug 8, 2025	DARPA pages, earlier in session	A	No matching design result
CLM-024 Dossier inconsistencies 1 to 8	Dossier text, Apr 11, 2026	A	Checked by me against text

Appendix B: Search Log

Supportive means it tended to favor the concept; disconfirming means it tended against; neutral is context. Eight page fetches failed (blocked, robots, or not allowlisted).

Topic searched	Direction	Outcome
Tularosa deception experiment	Supportive	Large effects; limits noted
Two-sided deception study	Neutral	No score difference
Honeypot detection research	Disconfirming	Titles found; main paper unreadable
Moving target defense critique	Disconfirming	Benefits smaller than expected
Potemkin honeyfarm	Neutral	Scale shown; limits admitted
MITRE Engage	Supportive	Framework exists; claims are marketing
Volt Typhoon advisory	Disconfirming	Advisory exists; page unreadable
SolarWinds dwell time	Disconfirming	Titles only
Mandiant dwell time (2024, 2026)	Disconfirming	Days to weeks
Ukraine grid 2015/2016	Disconfirming	Analyses exist; unreadable
Cyber Storm after-action reports	Neutral	Coordination findings
Locked Shields 2025	Neutral	Scale and scope
Salt Typhoon guidance	Disconfirming	Titles only; unverified
CSRB Log4j	Disconfirming	Inventory gaps
Honeypot evasion and informed attackers	Disconfirming	Informed attackers still affected
BGP convergence	Disconfirming	Minutes, not seconds
DNS TTL violations	Disconfirming	Small but real share
Internet-wide scanning speed	Neutral	About 44 minutes (2013)

Topic searched	Direction	Outcome
CISA 2015 status	Neutral	Extended to Sep 30, 2026
Honeypot law, entrapment	Neutral	Abstract only
Critical infrastructure ownership share	Disconfirming	Figure poorly sourced
DARPA BAA cyber deception	Neutral	Aggregators only; nothing verified
IBM breach cost 2025	Neutral	Scale reference
SLCGP status	Neutral	Unclear; page unreadable
Colonial Pipeline	Disconfirming	Credential entry; defender shutdown
NSF SaTC award sizes	Neutral	Sizes verified
DOE CESER funding	Neutral	Past announcements; amounts unverified
Berferd and Cuckoo's Egg	Supportive	Precedents; details unread
Deception vendor market	Neutral	Vendor names only
Earlier in session: SBIR/STTR, XD3, AIxCC, Roach Motel	Neutral	As noted in ledger

Appendix C: Precedent Register

Verified means I read enough to state the cited facts.

Precedent	Status	Result	Lesson
Tularosa and replication	Partly verified	Positive in lab	Selective decoys help; not scale
Potemkin honeyfarm	Verified	Scaled; detectable	Scans exhaust resources
Two-sided deception study	Verified	Inconclusive	Small samples mislead

Precedent	Status	Result	Lesson
Moving target defense	Abstract only	Smaller than expected	Rotation is not safety
MITRE Engage	Verified	Framework	Planning language, not proof
DARPA XD3	Verified exists	Completed	No matching result found
Cyber Storm IX	Verified	Exercise	Coordination fails first
Locked Shields 2025	Verified	Exercise	Tests defenders, not decoys
Log4j CSRB review	Verified	Failure	Inventory gaps persist
Colonial Pipeline	Verified (B)	Failure	Credentials; defender shutdown
Berferd, Cuckoo's Egg	Not read	Positive, small	Labor-intensive
Volt Typhoon, SolarWinds, Salt Typhoon, Ukraine grid	Not verified	Failures	Verify before use
Honeypot detection papers	Titles only	Detectable	Fidelity ceiling
Commercial deception vendors	Names only	Unknown	Market data missing

Appendix D: Bypass Taxonomy

Conceptual only. The last column asks what independent control protects the real asset.

#	Route	Evidence	Independent control needed
1	Valid credentials	Colonial (B)	Strong identity, MFA, monitoring

#	Route	Evidence	Independent control needed
2	Pre-positioned access	Dwell time days to months	Hunting; segmentation
3	Living off the land	Volt Typhoon advisory title	Behavior baselines
4	Edge devices	M-Trends 2026 blog	Logging; patch speed
5	Supply chain	SolarWinds (to verify)	Build integrity; SBOM
6	Detector or controller	Inference (D)	Independent detector; fail-closed
7	Induced false positives	Failure mode 2 in dossier	Rate limits; human review
8	Operator social engineering	Cyber Storm IX roles	Training; dual approval
9	Air-gap, OT, physical	Dossier failure mode 1	OT controls; physical security
10	Third-party piggyback	Dossier Scenario D	Vendor controls
11	Slow and low	Inference (D)	Long-window analytics
12	Non-access attacks	Inference (D)	Capacity; resilience
13	Attack the transfer	Cyber Storm IX sharing	Package integrity review
14	Recognition or displacement	Tularosa; Potemkin limits	Do not rely on secrecy

Appendix E: Cost Arithmetic

Effort figures are my planning assumptions (grade D). The three rates are assumed, not sourced. Cost = FTE-years × rate.

Scope	FTE-years	$200,000	$250,000	$350,000
1: 3 to 6 mo (3 people × 0.5 yr)	1.5	$300,000	$375,000	$525,000

Scope	FTE-years	$200,000	$250,000	$350,000
2: 6 to 12 mo (8 × 1 yr)	8	$1,600,000	$2,000,000	$2,800,000
3: 12 to 24 mo (20 × 2 yr)	40	$8,000,000	$10,000,000	$14,000,000

Compute, sensors, range time, licenses, legal, and sustainment are not included. National scale is not estimated.

Scope 2 minus NSF Medium cap ($1,200,000): $400,000 at $200,000; $800,000 at $250,000; $1,600,000 at $350,000.

Appendix F: Funding Pathways

Verified means status read from a source today. Always confirm on the agency page.

Pathway	Fit	Verified	To verify
SBIR/STTR	Small business, Scope 1 to 2	Lapse and reauthorization (secondary)	Agency pages, topics
NSF SaTC	Academic basic research	Award sizes (24-504)	Current solicitation
DARPA	Novel, high risk	XD3, AIxCC exist	Open topics, eligibility
DOE CESER	Energy-sector first segment	Past announcements exist	Amounts and topics
DHS S&T, IARPA	Applied, intelligence	Not verified	Programs
DIU, OTAs	Prototype to production	Not verified	Programs
SLCGP	State and local	Extension Nov 2025 (titles)	Current status
Private, hybrid	Pilot co-funding	Not verified	Interest

Appendix G: Change Register

Requests only. Each gives an in-universe explanation, a laboratory analogue, and the change request awaiting ONESTAMP.

ID	Issue	In-universe or lab	Request
CHG-001	Q17 cross-reference	Lab: not needed	Change Q17 to Q14 in §4.4
CHG-002	Tier labels inconsistent	Lab: pick one scheme	Adopt one tier scheme and apply everywhere
CHG-003	Five versus four scenarios	Lab: not needed	Correct count or add Scenario E
CHG-004	Overstated agreement	Lab: not needed	Report Copilot's Option B primary
CHG-005	Three seconds fixed or open	In: visible pulse; lab: sweep 3/30/300 s	Make ~3 s the visible cycle; underlying cadence tunable
CHG-006	Every attacker absorbed	In: all observed sessions resolved; lab: capture states	Replace with observed-resolved plus unknown
CHG-007	Silent migration	In: new sessions diverted; lab: EXP-004	State how established sessions are handled
CHG-008	Deception as sole protection	In: real assets hardened first; lab: fail-open test	Require independent real-asset controls
CHG-009	Transfer contents	In: reviewed package; lab: legal review	Define what is and is not transferred
CHG-010	Name count	Lab: not needed	Correct seven to 25 candidates
CHG-011	Partner and authority open	In: name or class; lab: G0	Resolve Q1, Q3 before drafting

ID	Issue	In-universe or lab	Request
CHG-012	Line vanishing equals safe	In: display shows states; lab: capture states	Add suspected, observed, diverted, verified, lost, unknown

Appendix H: Experiments, Gates, and Concept Note

Conceptual only. Owned or synthetic infrastructure. No real-target activity.

ID	Experiment or gate	Key measure or criterion
EXP-001	Literature and metrics review	Defined metrics; precedent register
EXP-002	Selective versus blanket decoys, equal budget	Data to real assets; alerts
EXP-003	Cycle sweep: 3, 30, 300 seconds	Legitimate-session breakage
EXP-004	Established sessions during diversion	Exposure window; session handling
EXP-005	Detector failure injection	Does diversion fail open
EXP-006	Independent bypass exercise	Routes that skip deception
EXP-007	Collateral on legitimate users	Latency, errors
G0	Concept clarity	Boundary, owner, purpose, metrics defined
G1	Research justification	Evidence, added value, known bypasses understood
G2	Safe prototype	Sandbox, oversight, budget, test plan
G3	Controlled pilot	Measured gain over baseline; rollback
G4	Scale decision	Independent review, authority, cost-benefit

Concept note outline: problem and asset boundary; hypothesis and baseline; three metrics; scope and duration; independent review; safety case; stop conditions.

Appendix I: Handoff Questions

Three questions for the Architect, three objections I expect, and three questions for each AI.

For	Question or objection
Architect	Which asset and owner is the first scope?
Architect	When feasibility and canon conflict, which wins?
Architect	Is the folder public or private?
Expected objection	Classified work exists that you cannot see.
Expected objection	Rotation helps even if its effect is small.
Expected objection	Canon is fiction; do not judge it as engineering.
ChatGPT	What equal-budget baseline would you use?
ChatGPT	What evidence beats Tularosa for scale?
ChatGPT	How would you measure capture?
Gemini	What are the sources for your cost and degradation figures?
Gemini	How does a honeyfarm handle established sessions?
Gemini	What is the best precedent for national scale?
Copilot	Which tier scheme should canon use?
Copilot	What legal authority fits the Architect?
Copilot	How would you audit capture?
Grok	What is the evidence for the self-reinforcing loop?
Grok	How do you prevent poisoning?

For	Question or objection
Grok	Which failure mode first?
Perplexity	Which dossier claims did you verify?
Perplexity	Which funding programs are open today?
Perplexity	What changed since April 11, 2026?

Appendix J: Sources

Every source I used, with what I read. Titles as seen.

Source	Used for
USENIX talk page on Tularosa and replication	CLM-001 to CLM-003
arXiv 2108.11037, Decoys in Cybersecurity	CLM-004
Vrable et al., Potemkin, SOSP 2005	CLM-005, CLM-006
Evans et al., Effectiveness of Moving Target Defenses, 2011	CLM-007
Labovitz et al., delayed routing convergence, 2001	CLM-008
SIDN Labs, DNS TTL violations with RIPE Atlas	CLM-009
ZMap paper, zmap.io	CLM-010
Help Net Security on M-Trends 2024	CLM-011
Blog on M-Trends 2026 (shashi.co), Jul 2026	CLM-012
CyberScoop on IBM 2025 report	CLM-013
CISA, Cyber Storm IX After-Action Report, Oct 2024	CLM-014
CCDCOE, Locked Shields 2025	CLM-015

Source	Used for
CISA, CSRB Log4j summary	CLM-016
TechTarget, Colonial Pipeline explainer	CLM-017
MITRE, Engage press release, Mar 2022	CLM-018
Lawfare, Turns Out It Is Not 85 Percent, Jun 2022	CLM-019
Mondaq, CISA 2015 reauthorization, Feb 2026	CLM-020
NSF 24-504 SaTC solicitation	CLM-021
Aradi and Bánáti, honeypots and law, SAMI 2026 (abstract)	WS7
Search-result titles: CISA AA24-038A; honeypot fingerprinting; E-ISAC Ukraine; SLCGP coverage; DOE CESER	Pointers, not findings

---

End of document. Research findings v1.0, prepared by Claude (Anthropic) on November 5, 2026. Advisory only; canon decisions and ONESTAMP remain with the Architect.